

SOC 2 TYPE II

System and Organization Controls
Trust Service Criteria Compliance Report

Portfolio Project | CloudVault SaaS Platform | Audit Period: January 1 - December 31, 2024

Prepared By	Organization	Auditor	Opinion
Cyber Security Analyst	CloudVault Inc.	Grant Thornton LLP	UNQUALIFIED

1. Executive Summary

This report presents a SOC 2 Type II compliance assessment for CloudVault Inc., a 75-employee SaaS company providing HR and payroll data-management services to over 200 enterprise clients. The audit was performed by Grant Thornton LLP (simulated) and covers the 12 months from January 1 to December 31, 2024.

SOC 2 is a voluntary security and compliance framework created by the American Institute of Certified Public Accountants (AICPA). It evaluates whether a company's controls meet the Trust Services Criteria (TSC): Security, Availability, Processing Integrity, Confidentiality, and Privacy. SOC 2 does not result in a certification; it results in an auditor-issued opinion shared with enterprise clients.

Item	Detail
Report type	SOC 2 Type II- 12-month continuous audit
Organization	CloudVault Inc.
Industry	Saas / HR Technology
Audit Period	January 1, 2024 - December 31, 2024

CPA Firm	Grant Thornton LLP (simulated)
Criteria in Scope	Security (CC) Availability (A) Processing Integrity (PL), Confidentiality (C)
Audit opinion	Unqualified - Controls operation effectively throughout the audit period

2. What is SOC 2?

2.1 Plain English Explanation

SOC 2 stands for System and Organization Controls 2. Think of it as a formal “security report card” written by an independent CPA firm. When an enterprise client asks:

“Can we trust you with our sensitive data?”

Your SOC 2 report is the answer.

Important points:

- SOC 2 is not a law — companies choose to undergo it to meet client expectations
- SOC 2 is not a certification — it is an attestation report issued by a CPA firm
- SOC 2 audits can only be performed by licensed CPAs
- Type I evaluates controls at a single point in time
- Type II evaluates controls over 6–12 months (much stronger)
- Most enterprise clients require SOC 2 Type II before signing contracts

2.2 SOC 2 Type I vs Type II

	SOC 2 Type I	SOC 2 Type II
What it test	Controls exist on one specific day	Controls operate consistently for 6–12 months
Duration	2–3 months to complete	6–12 months of monitoring
Trust level	Lower	Higher — proves real-world operation
Client preference	Startups/small clients	Required for enterprise clients

This project	Not applicable	This is a Type II implementation
--------------	----------------	----------------------------------

3. System Description & Scope

3.1 Trust Services Criteria in Scope

Criteria	Name	In Scope?	Why Included/ Excluded
CC	Security	YES	Mandatory for all SOC 2 audits
A	Availability	YES	Payroll services contractually require 99.9% uptime
PI	Processing Integrity	YES	Payroll accuracy is critical; errors create liability
C	Confidentiality	YES	Payroll & HR data is highly confidential
P	Privacy	NO	CloudVault does not collect consumer personal data (B2B SaaS)

4. Security Controls – Common Criteria (CC)

The Security (Common Criteria) category includes nine control areas (CC1–CC9). All were evaluated and found effective.

Code	Control Category	Status	CloudVault Implementation
CC1	Control Environment	EFFECTIVE	Security policies documented; CISO designated; background checks completed for all 75 employees.
CC2	Communication	EFFECTIVE	Policies communicated at onboarding and annual training; internal documentation maintained
CC3	Risk Assessment	EFFECTIVE	Full risk assessment completed Q1 2024; risks tracked and treated
CC4	Monitoring Activities	EFFECTIVE	24/7 SIEM monitoring via Datadog; alerts reviewed daily; monthly security meetings

CC5	Control Activities	EFFECTIVE	MFA enforced; AES-256 encryption; WAF deployed; patch-management SLA established; management SLA in place
CC6	Logical Access Controls	EFFECTIVE	RBAC implemented; MFA enforced; quarterly access reviews; immediate termination of access removal
CC7	System Operation	EFFECTIVE	IR plan tested Q2; change-management process established; on-call rotation active.
CC8	Change Management	EFFECTIVE	All code changes require peer review and staging-environment testing
CC9	Risk Mitigation	EFFECTIVE	Annual vendor risk assessments; BCP tested; cyber-insurance policy in place

5. Additional Trust Service Criteria

5.1 Availability (A)

Code	Requirement	Status	Evidence
A1.1	Some availability commitments documented	EFFECTIVE	SLAs for 99.9% uptime; contracts stored in CRM
A1.2	Availability monitor and alerts configure	EFFECTIVE	Datadog uptime alerts; PagerDuty alerts within 60 sec; 99.95% uptime achieved in 2024
A1.3	Recovery and backup procedures and place	EFFECTIVE	Daily automated S3 backups; quarterly DR tests; RTO = 4 hrs, RPO = 1 hr

5.2 Processing Integrity (PI)

Code	Requirement	Status	Evidence
PL1.1	Processing is complete and accurate	EFFECTIVE	Reconciliation checks run after each payroll cycle; zero uncorrected errors in 2024

PI1.2	Processing areas are identified and corrected	EFFECTIVE	Errors logged in Datadog; P1 errors corrected within 2 hours per SLA
PI1.2	Outputs are completed accurately and delivered	EFFECTIVE	Reconciliation reports generated; client receipts logged

5.3 Confidentiality (C)

Code	Requirement	Status	Evidence
CL1.1	Confidential info is identified and protected	EFFECTIVE	Data-classification policy enforced; HR/payroll data labeled "Confidential"; AES-256 encryption.
CI1.2	Confidential info is disposed of properly	EFFECTIVE	Data-retention schedule; client data deleted within 30 days post-contract; deletion certificates issued

6. Audit Evidence Collection

For SOC 2, Type II controls must be proven to have operated effectively every day during the 12-month audit period. The following evidence was collected and provided to the auditor, Grant Thornton LLP.

Evidence category	Frequency collected	Description of Evidence Provided
Access control logs	Quarterly	User account lists, MFA enrollment reports for all 75 employees
Incident Log	Continuous / Annual	Incident register for 2024; post-incident reviews for two P1 events
Change Management	Per deployment	847 production deployments with peer-review approvals
Vendor agreements	Annual	Signed contracts and BAAs for all 12 third- party vendors; annual security questionnaire responses

SIEM & monitoring	Continuous	12 months of Datadog alerts; documented investigations
Security training	Annual	Completion certificates for all staff; the auditor reviewed the training content
Back up and Recovery	Quarterly	DR test results (Q1 & Q3 2024); validated RTO/RPO targets
Vulnerability Scans	Monthly	12 Nessus reports; evidence of patching within SLA

7. Audit Opinion

7.1 Opinion Types Explain

Opinion type	Result	What it Means
Unqualified	PASS	All controls operated effectively
Qualified	PARTIAL	Some exceptions (still usable)
Adverse	FAIL	Controls are ineffective; cannot share the report

7.2 CloudVault Audit Opinion – 2024

UNQUALIFIED OPINION

Grant Thornton LLP – December 31, 2024

In our opinion, CloudVault Inc.'s system description fairly represents the systems designed and implemented during the audit period January 1, 2024, through December 31, 2024. The controls were suitably designed and operated effectively throughout the period to provide reasonable assurance that the applicable Trust Services Criteria were met.